

Rapport de Tests du site de la STR

1. Environnement de test

Composant	Version / Détail
Système d'exploitation	Windows 11
Serveur local	WAMP 3.4.0
PHP	8.3.28
MySQL	8.4.7
Navigateur principal	Microsoft Edge
Éditeur	Visual Studio Code
Base de données	str_db (10 tables, 2 événements planifiés)
URL de test	http://localhost/str_website/public/

2. Périmètre des tests

Les tests couvrent l'ensemble des fonctionnalités développées pendant le stage. Ils sont organisés en 4 niveaux conformément aux bonnes pratiques du cycle en V.

Niveau	Description	Nombre de tests
Tests d'intégration	Vérification de la communication entre les composants (PHP ↔ MySQL, handlers ↔ sessions, emails)	22
Tests fonctionnels	Validation des fonctionnalités du point de vue utilisateur	78
Tests de sécurité	Vérification des protections contre les attaques et les accès non autorisés	17
Tests d'acceptation	Validation par le client (club) que le site répond aux besoins exprimés	En attente
Total		117 + acceptation

3. Classification des anomalies

Sévérité	Définition	Couleur
Critique	Le site est inutilisable ou une faille de sécurité est exploitable	
Majeur	Une fonctionnalité importante ne fonctionne pas	
Mineur	Défaut cosmétique ou comportement inattendu sans impact fonctionnel	

4. Tests d'intégration

Objectif : vérifier que les composants techniques communiquent correctement entre eux.

4.1 Base de données ↔ Application PHP

N°	Test	Résultat	Observation
I-01	Connexion PDO à la base str_db	OK	PDO avec ERRMODE_EXCEPTION, FETCH_ASSOC, EMULATE_PREPARES = false
I-02	Lecture des rôles via requête SELECT	OK	3 rôles affichés correctement (admin, personnel, adherent)
I-03	Insertion d'un utilisateur (INSERT + lastInsertId)	OK	Clé étrangère role_id vérifiée
I-04	Insertion d'une licence liée à un utilisateur	OK	Clé étrangère user_id vérifiée
I-05	Suppression en cascade (DELETE user → licences supprimées)	OK	ON DELETE CASCADE fonctionnel
I-06	Restriction de suppression (DELETE user avec articles → refusé)	OK	ON DELETE RESTRICT sur posts.author_id

4.2 Événements MySQL automatisés

N°	Test	Résultat	Observation
I-07	event_scheduler activé	OK	SHOW VARIABLES LIKE 'event_scheduler' → ON

I-08	evt_deactivate_expired_accounts : licence expirée → status = expired	OK	Testé avec ALTER EVENT EVERY 1 MINUTE
I-09	evt_delete_expired_accounts : expired > 2 mois → compte supprimé	OK	

4.3 Handlers ↔ Sessions ↔ Redirections

N°	Test	Résultat
I-10	handle-contact.php → stocke erreurs en session → affichées sur contact.php	OK
I-11	handle-contact.php → stocke succès en session → affiché sur contact.php	OK
I-12	handle-register.php → stocke form_old en session → champs pré-remplis	OK
I-13	handle-login.php → session_regenerate_id → session sécurisée	OK
I-14	handle-logout.php → \$_SESSION = [] + session_destroy + setcookie → session détruite	OK

4.4 Système d'emails (mode DEV)

N°	Test	Résultat	Observation
I-15	sendContactEmail() → logs/mail.log	OK	Email logué avec destinataire, sujet, corps
I-16	sendEmailToUser() pour activation de compte → logs/mail.log	OK	
I-17	sendEmailToUser() pour refus → logs/mail.log	OK	
I-18	sendEmailToUser() pour reset mot de passe → logs/mail.log avec lien token	OK	
I-19	sendEmailToUser() pour renouvellement → logs/mail.log	OK	

4.5 Éditeur Quill ↔ BDD

N°	Test	Résultat	Observation
I-20	content_delta copié dans le champ hidden avant submit	OK	JavaScript quill.getContents()

I-21	content_html copié dans le champ hidden avant submit	OK	JavaScript quill.root.innerHTML
I-22	Rechargement du contenu Delta en mode modification	OK	quill.setContents() avec le Delta stocké

Anomalies détectées et corrigées :

N°	Sévérité	Description	Correction
I-B01		<code>password_resets.expires_at</code> calculé en PHP avec <code>strtotime('+1 hour')</code> donnait des résultats erronés (fuseaux horaires PHP ≠ MySQL)	Remplacé par <code>DATE_ADD(NOW(), INTERVAL 1 HOUR)</code> côté MySQL
I-B02		<code>sendEmailToUser()</code> appelé en dehors du <code>if</code> vérifiant l'existence du compte dans <code>handle-renew.php</code> → crash PHP	Déplacé à l'intérieur du bloc conditionnel

5. Tests fonctionnels

Objectif : valider que chaque fonctionnalité répond au besoin utilisateur.

5.1 Formulaire de contact

N°	Test	Résultat	Observation
F-01	Soumission formulaire vide (novalidate)	OK	4 messages d'erreur affichés
F-02	Remplissage partiel (2 champs sur 4)	OK	Erreurs + champs remplis conservés
F-03	Email invalide ("abc")	OK	"Entrez un email valide"
F-04	Soumission correcte	OK	Message vert "Votre message a bien été envoyé"
F-05	Vérification stockage en BDD (contact_messages)	OK	
F-06	Vérification audit_log (action = contact_form)	OK	
F-07	Rafraîchissement après succès → message ne réapparaît pas	OK	<code>unset(\$_SESSION['flash_success'])</code>

F-08	Message vert disparaît après 5 secondes	OK	Transition CSS via JavaScript
F-09	Validation HTML5 native (sans novalidate)	OK	Navigateur bloque "Veuillez remplir ce champ"
F-10	Honeypot anti-spam : champ caché rempli → redirection silencieuse	OK	

5.2 Inscription

N°	Test	Résultat	Observation
F-11	Cases décochées → bouton grisé	OK	JavaScript register.js
F-12	Cocher 1 seule case → bouton reste grisé	OK	
F-13	Cocher les 2 cases → bouton s'active	OK	
F-14	Barre de force : "abc" → rouge + "Mot de passe faible"	OK	
F-15	Barre de force : "MonSuperMdp1!" → verte + "Mot de passe fort"	OK	
F-16	Effacer le mot de passe → barre disparaît	OK	
F-17	Mot de passe < 12 caractères	OK	"au moins 12 caractères"
F-18	Mot de passe sans majuscule	OK	
F-19	Mot de passe sans chiffre	OK	
F-20	Mot de passe sans caractère spécial	OK	
F-21	Mots de passe différents	OK	"ne correspondent pas"
F-22	Inscription correcte → message "en attente de validation"	OK	
F-23	BDD : status = pending, role_id = 3	OK	

F-24	BDD : licence avec dates temporaires (2000-01-01)	OK	
F-25	Même email → "email déjà utilisée"	OK	
F-26	Même licence → "licence déjà utilisée"	OK	
F-27	Champs pré-remplis après erreur (sauf mot de passe)	OK	

5.3 Connexion

N°	Test	Résultat	Observation
F-28	Email inexistant → "Email ou mot de passe incorrect"	OK	Même message (sécurité)
F-29	Email correct, mauvais mdp → même message	OK	
F-30	Compte PENDING → "en attente de validation"	OK	
F-31	Compte EXPIRED → redirige vers renouvellement.php	OK	Pas de double message
F-32	Compte REJECTED → "inscription refusée"	OK	
F-33	Adhérent ACTIVE → redirige index.php + header "Bonjour Prénom"	OK	
F-34	Admin ACTIVE → redirige admin/dashboard.php	OK	
F-35	Personnel ACTIVE → redirige admin/dashboard.php	OK	
F-36	Avatar avec initiales affiché	OK	

5.4 Déconnexion

N°	Test	Résultat
F-37	Clic déconnexion → retour accueil + header visiteur	OK
F-38	Bouton "Retour" navigateur → pas de retour connecté	OK

5.5 Mot de passe oublié

N°	Test	Résultat	Observation
F-39	Email existant → "Si un compte existe, un email a été envoyé"	OK	
F-40	Email inexistant → même message (sécurité)	OK	
F-41	Lien dans mail.log → formulaire nouveau mot de passe	OK	
F-42	Barre de force sur la page de reset	OK	reset-password.js
F-43	Mot de passe valide → redirige login + "Mot de passe réinitialisé"	OK	
F-44	Se connecter avec le nouveau mot de passe	OK	
F-45	Réutiliser le même lien → "Lien invalide ou expiré"	OK	used_at IS NULL vérifié
F-46	BDD : used_at rempli après utilisation	OK	

5.6 Renouvellement

N°	Test	Résultat
F-47	Formulaire affiché	OK
F-48	Email + licence valides → "Demande envoyée"	OK
F-49	BDD : status repassé à pending	OK
F-50	Emails : admin notifié + confirmation au demandeur	OK
F-51	Email inexistant → même message (sécurité)	OK
F-52	Mauvaise correspondance email/licence → même message	OK

5.7 Back-office — Dashboard

N°	Test	Résultat	Observation
F-53	Admin : stats adhérents (pending/active/expired/rejected)	OK	Comptés par role_id = 3

F-54	Admin : nombre de personnel	OK	Compté par role_id = 2
F-55	Personnel : infos personnelles affichées	OK	JOIN users + roles + licences

5.8 Back-office — Gestion des comptes

N°	Test	Résultat
F-56	Tableau des adhérents par défaut	OK
F-57	Filtre "Personnel" → tableau + formulaire création	OK
F-58	Filtre par statut	OK
F-59	Recherche par nom/prénom/email/licence	OK
F-60	Clic sur ligne → modale avec détails (AJAX)	OK
F-61	Valider pending → active + dates licence mises à jour	OK
F-62	Refuser → rejected + email de refus	OK
F-63	Renouveler expiré → active + nouvelle licence insérée	OK
F-64	Supprimer → confirmation → compte supprimé	OK
F-65	Auto-suppression → "Vous ne pouvez pas"	OK
F-66	Suppression avec articles → "Impossible, réattribuez d'abord"	OK
F-67	Créer un personnel → email envoyé (sans mdp dans l'email)	OK
F-68	Ancre #liste → scroll au tableau après action	OK

5.9 Back-office — Gestion des articles

N°	Test	Résultat
F-69	Liste de tous les articles	OK
F-70	Recherche par titre	OK
F-71	Filtre par catégorie	OK
F-72	Filtre par statut (brouillon/publié)	OK

F-73	Créer un article PUBLIC → publier	OK
F-74	Article visible sur actualite.php (visiteur)	OK
F-75	"Lire la suite" → article complet sur article.php	OK
F-76	Créer un article ADHÉRENT → pas visible non connecté	OK
F-77	Article adhérent visible quand connecté	OK
F-78	Sauvegarder brouillon → pas visible sur actualite.php	OK
F-79	Modifier un article → titre changé	OK
F-80	Supprimer un article → confirmation → supprimé	OK
F-81	Slug sans accents ("Résultats" → "resultats")	OK
F-82	Deux articles même titre → slugs différents (timestamp)	OK

5.10 Page adhérent (mon-compte.php)

N°	Test	Résultat	Observation
F-83	Infos personnelles affichées	OK	
F-84	Téléphone non renseigné → "Non renseigné"	OK	Opérateur ? : pour chaîne vide
F-85	6 derniers articles adhérents avec filtres catégorie	OK	
F-86	Carrousel comité directeur : flèches + dots + défilement auto	OK	
F-87	Carrousel : pause au survol	OK	
F-88	Bouton balle retour en haut (article.php uniquement)	OK	Rotation -90deg, visible dans zone article

Anomalies détectées et corrigées :

N°	Sévérité	Description	Correction
F-B01		Message "Bienvenue" de la connexion apparaissait sur contact.php	Supprimé le message flash de bienvenue

F-B02		Redirection expired affichait erreur + message renouvellement (doublon)	Supprimé le message d'erreur, seul renouvellement.php informe
F-B03		Barre de force mot de passe grise sous 8 caractères	Modifiée pour être rouge dès le 1er caractère
F-B04		Faute de frappe "Veuillez" dans handle-login.php	Corrigé en "Veuillez"
F-B05		Doublon Actualité membre dans mon-compte.php	Supprimé le doublon

6. Tests de sécurité

Objectif : vérifier que le site résiste aux attaques courantes et que le contrôle d'accès est respecté.

6.1 Contrôle d'accès

N°	Test	Résultat	Observation
S-01	Visiteur → admin/dashboard.php	OK	Redirige vers login.php
S-02	Visiteur → admin/users.php	OK	Redirige vers login.php
S-03	Visiteur → admin/editor.php	OK	Redirige vers login.php
S-04	Adhérent → admin/dashboard.php	OK	Redirige vers login.php
S-05	Adhérent → admin/users.php	OK	Redirige vers login.php
S-06	Personnel → admin/users.php	OK	Redirige vers login.php (admin seul)
S-07	Visiteur → mon-compte.php	OK	Redirige vers login.php
S-08	Visiteur → URL article adhérent	OK	Redirige vers login.php avec message
S-09	Nom de l'auteur masqué pour les non connectés	OK	if (isLoggedIn()) dans article.php

6.2 Protection des données

N°	Test	Résultat	Observation
S-10	Mots de passe hashés en BDD (\$2y\$12\$...)	OK	bcrypt cost 12, jamais en clair
S-11	Token de reset hashé en SHA-256 en BDD	OK	Seul le hash est stocké
S-12	Cookies → seulement PHPSESSID	OK	Pas de cookie de tracking

6.3 Protection contre les attaques

N°	Test	Résultat	Observation
S-13	Injection SQL : caractères spéciaux dans les champs	OK	Requêtes préparées PDO sur 100% des requêtes
S-14	CSRF : soumission sans token → "Session expirée"	OK	Token vérifié sur tous les formulaires
S-15	XSS : <script>alert('xss')</script> dans un champ	OK	htmlspecialchars() à l'affichage
S-16	Fixation de session : session_regenerate_id à la connexion	OK	
S-17	Audit log : chaque action sensible tracée avec IP	OK	

Anomalies détectées et corrigées :

N°	Sévérité	Description	Correction
S-B01		header-admin.php : header('BASE_URL', '/login.php') au lieu de header('Location: ' . BASE_URL '/login.php') → la redirection de sécurité ne fonctionnait pas	Syntaxe corrigée
S-B02		user-detail.php : requireRole('admin') faisait une redirection HTML dans un contexte AJAX	Remplacé par http_response_code(403)

		→ le JS recevait le HTML de login dans la modale	
S-B03		Token CSRF placé en dehors de la balise <form> → jamais envoyé avec le POST	Déplacé à l'intérieur du formulaire
S-B04		htmlspecialchars() appliqué au stockage dans test_input() → données corrompues en BDD	Déplacé à l'affichage uniquement

7. Tests de chemins et navigation (BASE_URL)

Objectif : vérifier que tous les liens, images et redirections fonctionnent après la migration vers BASE_URL.

N°	Test	Résultat	Observation
N-01	Pages publiques → toutes les images chargées	OK	
N-02	Pages admin → toutes les images chargées	OK	
N-03	Footer → images et liens depuis n'importe quelle page	OK	
N-04	Déconnexion depuis le back-office	OK	
N-05	Ancres (#presentation, #tarif, etc.)	OK	ajout scroll-padding-top
N-06	Console F12 → aucune erreur JS rouge	OK	

Anomalies détectées et corrigées :

N°	Sévérité	Description	Correction
N-B01		CSS collé dans app.js → erreur de syntaxe → tout le JavaScript planté (hamburger, alertes, carrousel)	CSS déplacé dans style.css
N-B02		handle-logout.php ne chargeait pas db.php → BASE_URL indéfinie → Fatal error	Ajout de require_once db.php

N-B03		handle-contact.php : double préfixe BASE_URL . ' /str_website/public/contact.php'	Supprimé le doublon
N-B04		users.php : PHP dans JavaScript fetch(BASE_URL . '/admin/...') au lieu de '<?= BASE_URL ?>/admin/...'	Injection PHP dans JS via <?= ?>
N-B05		article.php : espace dans le chemin BASE_URL ?> /assets	Espace supprimé
N-B06		balle.svg.svg → double extension de fichier	Renommé en balle.svg
N-B07		Chemins relatifs restants dans register.php, login.php, le-club.php, index.php	Tous migrés vers BASE_URL

8. Synthèse des anomalies

8.1 Répartition par sévérité

Sévérité	Détectées	Corrigées	Restantes
	6	6	0
	7	7	0
	7	7	0
Total	20	20	0

8.2 Répartition par catégorie

Catégorie	Nombre	Exemples
Chemins et require	7	Double préfixe BASE_URL, espace dans le chemin, fichier non chargé
Sécurité	4	CSRF hors formulaire, header() mal formé, requireRole en AJAX
Logique métier	4	sendEmailToUser hors du if, message doublon, fuseau horaire
Variables et syntaxe	3	\$users vs \$user, guillemets manquants, alias SQL incorrect

JavaScript	1	CSS collé dans le fichier JS
Interface	1	Barre de force mot de passe grise

9. Mesures de sécurité validées

Mesure	Implémentation	Statut
Hashage des mots de passe	bcrypt cost 12 via password_hash()	Validé
Protection injection SQL	Requêtes préparées PDO (100% des requêtes)	Validé
Protection CSRF	Token à usage unique sur tous les formulaires	Validé
Protection XSS	htmlspecialchars() sur toutes les données affichées	Validé
Contrôle d'accès par rôle	requireLogin(), requireRole(), hasRole()	Validé
Régénération de session	session_regenerate_id(true) à la connexion	Validé
Anti-spam	Honeypot sur formulaires contact et renouvellement	Validé
Journalisation	Toutes les actions sensibles tracées dans audit_log	Validé
Minimisation des données	Collecte du strict nécessaire (conformité RGPD)	Validé
Tokens de reset sécurisés	Token hashé SHA-256, expiration 1h, usage unique	Validé

10. Tests d'acceptation (à planifier)

Ces tests doivent être réalisés avec le client avant la mise en production.

N°	Scénario	Validé par	Date
A-01	La présidente crée un compte admin et navigue dans le back-office		
A-02	Un membre du bureau inscrit un adhérent fictif et valide son compte		

A-03	Un membre du personnel rédige et publie un article via Quill		
A-04	Un adhérent se connecte, consulte les articles réservés et son espace		
A-05	Un visiteur remplit le formulaire de contact et le club reçoit le message		
A-06	Le club valide que le contenu des pages (textes, photos, horaires) est correct		
A-07	Le club teste le site sur mobile (smartphone)		

11. Conclusion

L'ensemble des tests d'intégration, fonctionnels et de sécurité ont été exécutés avec succès. Les 20 anomalies détectées pendant le développement ont toutes été corrigées et retestées. Aucune anomalie résiduelle n'est connue à la date de ce rapport.

Le site est prêt pour la phase de recette client (tests d'acceptation) et la mise en production après validation par le bureau du club.

Prochaines étapes :

1. Planifier la session de recette
2. Corriger les éventuels retours client
3. Configurer l'hébergement OVH Pro
4. Déployer en production (transfert FTP, import BDD, configuration PHPMailer)
5. Effectuer un test de non-régression post-déploiement